

WHITE PLAINS HOSPITAL | HIPAA GAP REMEDIATION ROADMAP | April 2026

IMMEDIATE — 30 Days | April to May 2026 | 4 items

Priority	HIPAA Section	Control Name	Remediation Action	Owner	Status	Target Date	Notes
Critical	§164.308(a)(1)(ii)(A)	Risk Analysis	Conduct formal annual risk assessment. Document findings in risk register. Report to leadership.	GRC Analyst	Not Met	April 2026	Risk analysis scoping initiated. Assign GRC Analyst as lead by April 15.
Critical	§164.308(a)(6)(i)	Security Incident Procedures	Develop formal incident response plan. Define roles, procedures, and communication protocols.	GRC Analyst / CISO	Not Met	May 2026	IRP template selected. Draft due May 15. Tabletop exercise scheduled June 2026.
Critical	§164.308(a)(7)(i)	Contingency Plan	Develop contingency plan with defined RTO and RPO. Document backup procedures. Test annually.	IT Manager / GRC Analyst	Not Met	July 2026	INITIATE IMMEDIATELY — RTO/RPO scoping by April 30. Full plan delivery July 2026.
Critical	§164.314(a)(1)	Business Associate Contracts	Audit all vendor contracts for BAA compliance. Obtain missing BAAs. Implement vendor BAA tracker.	GRC Analyst / Legal	Not Met	May 2026	Vendor contract list pulled. BAA audit in progress. Tracker template created.

SHORT TERM — 60 Days | May to June 2026 | 9 items

Priority	HIPAA Section	Control Name	Remediation Action	Owner	Status	Target Date	Notes
Critical	§164.308(a)(1)	Security Management Process	Establish formal security management program. Document all policies. Create quarterly review schedule.	CISO / GRC Analyst	Partially Met	May 2026	Policy framework selected (NIST CSF). Drafting begins May 2026.
Critical	§164.308(a)(1)(ii)(B)	Risk Management	Create and maintain formal risk register. Document treatment plans for all identified risks.	GRC Analyst	Partially Met	May 2026	Risk register template complete. Population from gap assessment underway.
Critical	§164.308(a)(5)(i)	Security Awareness and Training	Expand training program to include cybersecurity awareness. Add phishing simulation exercises quarterly.	HR Manager / GRC Analyst	Partially Met	May 2026	LMS vendor selected. Phishing simulation vendor evaluated.
Critical	§164.308(a)(5)(ii)(B)	Protection from Malicious Software	Deploy enterprise EDR solution. Implement malware awareness in training program. Establish reporting procedures.	IT Manager	Partially Met	June 2026	EDR vendor shortlist created. Procurement approval pending.
Critical	§164.308(a)(5)(ii)(D)	Password Management	Enforce password policy technically on all systems. Implement MFA. Deploy enterprise password manager.	IT Manager	Partially Met	May 2026	Password policy updated. MFA deployment plan drafted.
Critical	§164.308(a)(7)(ii)(A)	Data Backup Plan	Implement automated daily cloud backup. Verify backup integrity monthly. Document backup procedures.	IT Manager	Partially Met	May 2026	Cloud backup vendor selected. Automated backup configured.
Critical	§164.312(a)(1)	Access Control	Implement role-based access control across all ePHI systems. Enforce minimum necessary access.	IT Manager	Partially Met	May 2026	RBAC matrix being designed for Epic EHR and key systems.

Critical	§164.312(a)(2)(i)	Unique User Identification	Eliminate all shared accounts. Assign unique identifiers to all users on all ePHI systems.	IT Manager	Partially Met	May 2026	Shared account audit complete. 3 accounts identified for remediation.
Critical	§164.312(d)	Person or Entity Authentication	Deploy MFA on all systems containing ePHI. Prioritize Epic EHR and remote access.	IT Manager	Partially Met	May 2026	MFA rollout plan approved. Pilot group deployment May 15.

MEDIUM TERM — 90 Days June to July 2026 16 items							
Priority	HIPAA Section	Control Name	Remediation Action	Owner	Status	Target Date	Notes
High	§164.308(a)(1)(ii)(C)	Sanction Policy	Update HR disciplinary policy to include specific ePHI security violations and tiered consequences.	HR Manager / GRC Analyst	Partially Met	June 2026	In Progress
High	§164.308(a)(1)(ii)(D)	Information System Activity Review	Implement monthly audit log review process. Assign Privacy Officer responsibility. Create review template.	Privacy Officer	Partially Met	May 2026	In Progress
High	§164.308(a)(3)(i)	Workforce Authorization and Supervision	Implement formal written access authorization process. Document all ePHI access approvals.	IT Manager / HR Manager	Partially Met	June 2026	In Progress
High	§164.308(a)(3)(ii)(A)	Authorization and Supervision	Create role-based access control matrix. Map each job role to minimum necessary access level.	IT Manager	Partially Met	June 2026	In Progress
High	§164.308(a)(3)(ii)(C)	Termination Procedures	Create formal IT offboarding checklist. Automate account deactivation. Audit monthly for orphaned accounts.	IT Manager / HR Manager	Partially Met	May 2026	In Progress
High	§164.308(a)(4)(i)	Information Access Management	Document comprehensive information access management policy with ePHI-specific requirements.	Privacy Officer / GRC Analyst	Partially Met	June 2026	In Progress
High	§164.308(a)(4)(ii)(B)	Access Authorization	Implement formal access request and authorization workflow with documented approvals and review.	IT Manager	Not Met	June 2026	In Progress
High	§164.308(a)(5)(ii)(C)	Log-in Monitoring	Configure automated alerts for failed login attempts and after-hours access. Assign monitoring owner.	IT Manager	Partially Met	June 2026	In Progress
High	§164.308(a)(8)	Evaluation	Implement annual HIPAA Security Rule evaluation. Document findings. Report to leadership.	GRC Analyst	Not Met	July 2026	In Progress
High	§164.310(a)(1)	Facility Access Controls	Install key card access on server room. Implement visitor log. Document physical access procedures.	Facilities Manager / IT Manager	Not Met	July 2026	In Progress
High	§164.310(d)(1)	Device and Media Controls	Implement certified data destruction process for all retired devices. Document disposal records.	IT Manager	Not Met	June 2026	In Progress

High	§164.312(a)(2)(iv)	Encryption and Decryption	Implement full disk encryption on all devices. Enforce encrypted email for all PHI communications.	IT Manager	Partially Met	June 2026	In Progress
High	§164.312(b)	Audit Controls	Formalize audit log review process. Schedule monthly reviews. Document findings and escalate anomalies.	Privacy Officer / GRC Analyst	Partially Met	May 2026	In Progress
High	§164.312(e)(1)	Transmission Security	Implement TLS encryption for all internal ePHI transmissions. Enforce encrypted email for PHI.	IT Manager	Partially Met	June 2026	In Progress
High	§164.316(a)	Policies and Procedures	Complete policy suite development. Implement annual policy review schedule. Track implementation.	GRC Analyst / CISO	Partially Met	June 2026	In Progress
High	§164.316(b)(1)	Documentation	Implement centralized document management system. Apply 6-year retention policy to all security documentation.	GRC Analyst	Not Met	July 2026	In Progress

ONGOING Quarterly Reviews 7 items							
Priority	HIPAA Section	Control Name	Remediation Action	Owner	Status	Target Date	Notes
Medium	§164.308(a)(2)	Assigned Security Responsibility	Document formal security responsibility assignments. Establish GRC Analyst role with defined responsibilities.	CISO	Partially Met	May 2026	In Progress
Medium	§164.308(a)(3)(ii)(B)	Workforce Clearance Procedure	Implement quarterly user access reviews. Verify access remains appropriate for current job function.	HR Manager / IT Manager	Partially Met	July 2026	In Progress
Medium	§164.310(a)(2)(ii)	Facility Security Plan	Document facility security plan covering server room, workstation areas, and clinical systems.	Facilities Manager	Partially Met	August 2026	In Progress
Medium	§164.310(b)	Workstation Use	Develop workstation use procedures for clinical areas. Include clean desk and screen lock requirements.	GRC Analyst / IT Manager	Partially Met	June 2026	In Progress
Medium	§164.310(c)	Workstation Security	Deploy privacy screens on workstations in high-traffic areas. Verify screen lock settings on all devices.	IT Manager	Partially Met	July 2026	In Progress
Medium	§164.312(a)(2)(iii)	Automatic Logoff	Verify and enforce automatic logoff settings on all workstations and clinical devices. Set maximum 10 minutes.	IT Manager	Partially Met	June 2026	In Progress
Medium	§164.312(c)(1)	Integrity	Implement file integrity monitoring across all ePHI systems. Document integrity controls.	IT Manager	Partially Met	July 2026	In Progress